CLOUD SECURITY LAB PORTFOLIO

AWS IAM အသုံးပြုခွင့် စီမံခန့်ခွဲခြင်းနှင့် ဝင်ရောက်ခွင့် စမ်းသပ်မှု

Users Groups Policies Amazon S3 Amazon EC2

Lab portfolio report | စက်တင်ဘာ ၂၀၂၆

အနှစ်ချုပ်

ဤ lab တွင် AWS Identity and Access Management (IAM) ၏ user၊ group နှင့် policy များကို စစ်ဆေးပြီး လုပ်ငန်းတာဝန်အလိုက် access ခွဲဝေပေးခဲ့သည်။ ထို့နောက် IAM user သုံးဦးအဖြစ် သီးခြား sign in ဝင်ကာ Amazon S3 နှင့် Amazon EC2 တွင် ခွင့်ပြုထားသော လုပ်ဆောင်ချက်များ အလုပ်လုပ်မှုကို စမ်းသပ်ခဲ့သည်။

ရလဒ်အရ user-1 သည် S3 bucket ကို ဖွင့်ကြည့်နိုင်သော်လည်း EC2 အချက်အလက်ရယူမှု ငြင်းပယ်ခံရသည်။ user-2 သည် EC2 instance ကို ကြည့်နိုင်သော်လည်း S3 bucket list ကို မကြည့်နိုင်ပါ။ user-3 သည် EC2 instance ကို stop လုပ်ရန် တောင်းဆိုမှု အောင်မြင်ပြီး state သည် Stopping သို့ ပြောင်းလဲခဲ့သည်။ ဤရလဒ်များက group မှတစ်ဆင့် permission ပေးထားမှုနှင့် least privilege စည်းမျဉ်းကို လက်တွေ့ပြသသည်။

၁ Project overview

လုပ်ငန်းအဖွဲ့တစ်ခုတွင် ဝန်ထမ်းအသစ်သုံးဦးကို S3 support၊ EC2 support နှင့် EC2 operations တာဝန်များအလိုက် access ပေးရန် လိုအပ်သည့် scenario ကို အခြေခံထားသည်။ IAM user တစ်ဦးချင်းစီသို့ policy တိုက်ရိုက်ထည့်ခြင်းထက် group အလိုက် policy သတ်မှတ်ပြီး သက်ဆိုင်ရာ user ကို group ထဲသို့ ထည့်သွင်းခဲ့သည်။

၂ ရည်ရွယ်ချက်များ

- IAM users နှင့် user groups ၏ မူလအခြေအနေကို စစ်ဆေးရန်
- AWS managed policy နှင့် customer inline policy တို့၏ ခွင့်ပြုချက်များကို ဖတ်ရှုရန်
- လုပ်ငန်းတာဝန်အလိုက် user သုံးဦးကို သက်ဆိုင်ရာ group များသို့ ချိတ်ဆက်ရန်
- IAM user အဖြစ် sign in ဝင်၍ ခွင့်ပြုထားသည့် access နှင့် ငြင်းပယ်ခံရသည့် access ကို အတည်ပြုရန်

၃ Lab environment နှင့် business scenario

AWS Management Console ပါဝင်သော lab environment တွင် IAM users သုံးဦး၊ user groups သုံးခုနှင့် Amazon EC2 instance တစ်ခုကို အသုံးပြုခဲ့သည်။ S3 bucket ကို ဖွင့်ကြည့်ခြင်းနှင့် EC2 instance ကို ကြည့်ခြင်း၊ stop လုပ်ခြင်းတို့ကို စမ်းသပ်ခဲ့သည်။ Screenshot များတွင် EC2 resource သည် US East (N. Virginia) region ၌ ရှိသည်။

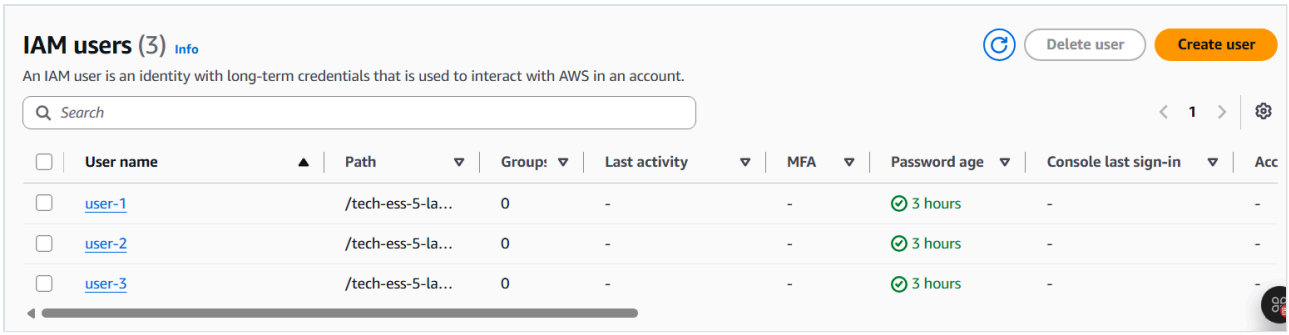
IAM user	တာဝန်နှင့် group	ရည်မှန်း access
user-1	S3-Support	Amazon S3 read only
user-2	EC2-Support	Amazon EC2 read only
user-3	EC2-Admin	EC2 instance view, start, stop

S3-Support နှင့် EC2-Support တွင် AWS managed read only policy များ ပါဝင်ပြီး EC2-Admin တွင် EC2-Admin-Policy inline policy ပါဝင်သည်။ Screenshot များအရ support group နှစ်ခုနှင့် admin group တွင် RegionPinningPolicy ဟုခေါ်သော customer managed policy လည်း တွဲထားသည်။ ယင်း policy ၏ အသေးစိတ် rule များကို screenshot များက မပြသသောကြောင့် ၎င်း၏ အကျိုးသက်ရောက်မှုကို ဤ report တွင် အကဲဖြတ်မထားပါ။

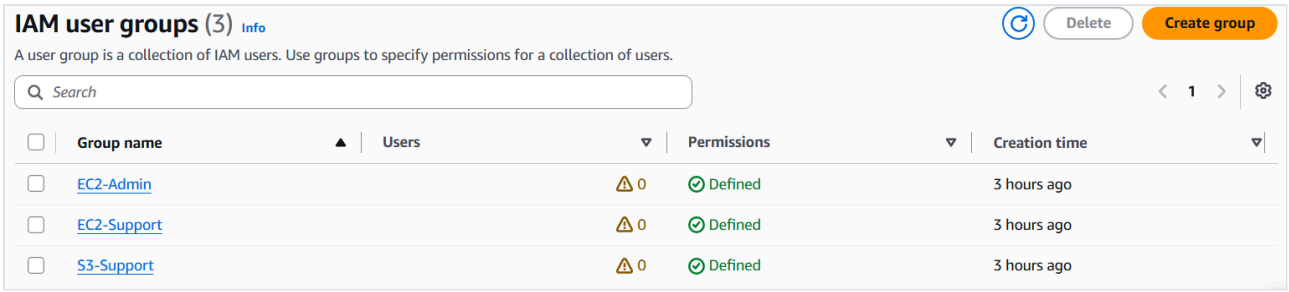
၄ Implementation နှင့် configuration

၄.၁ မူလ IAM အခြေအနေ စစ်ဆေးခြင်း

IAM users စာရင်းတွင် user-1၊ user-2၊ user-3 သုံးဦးကို တွေ့ရပြီး စတင်ချိန်တွင် group count သည် 0 ဖြစ်သည်။ IAM user groups စာရင်းတွင် EC2-Admin၊ EC2-Support၊ S3-Support သုံးခု ရှိပြီး user count သည် 0 ဖြစ်သည်။ user-1 ၏ group membership စာမျက်နှာကလည်း group မရှိသေးကြောင်း ပြသသည်။



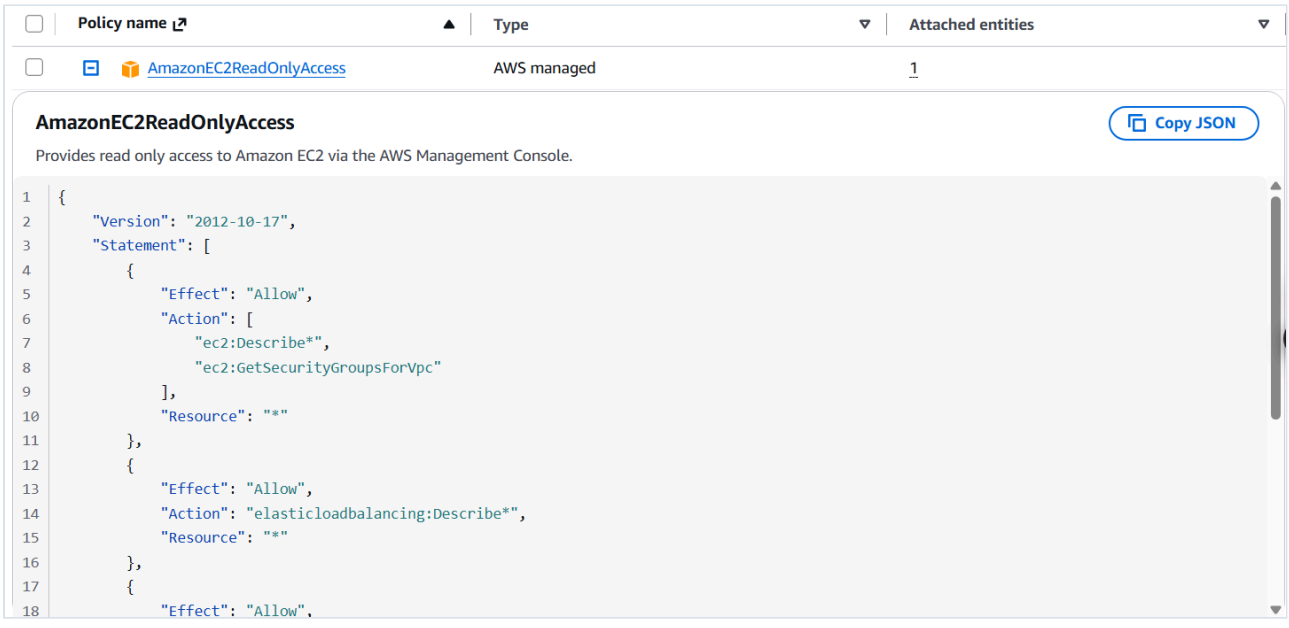
ပုံ 1 စတင်ချိန်တွင် IAM user သုံးဦး၏ group count သည် 0 ဖြစ်နေသည်။



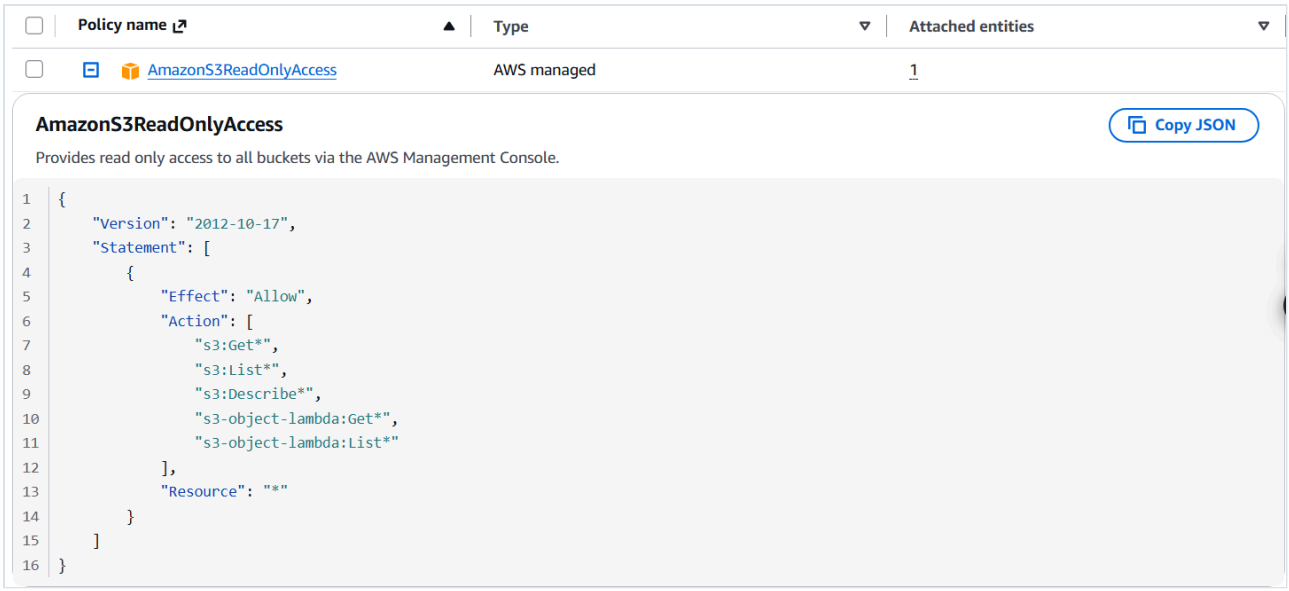
ပုံ 2 EC2-Admin၊ EC2-Support နှင့် S3-Support group သုံးခုကို စစ်ဆေးထားသည်။

၄.၂ Policy များကို စစ်ဆေးခြင်း

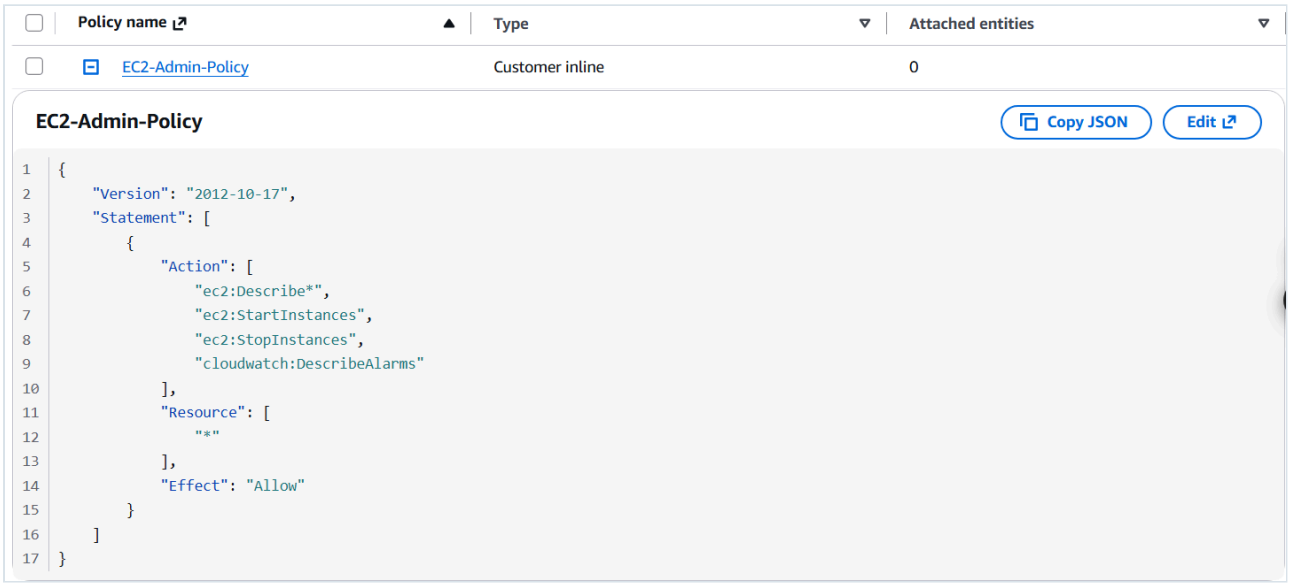
EC2-Support တွင် AmazonEC2ReadOnlyAccess AWS managed policy ရှိပြီး EC2 describe လုပ်ဆောင်ချက်များကို ခွင့်ပြုထားသည်။ S3-Support တွင် AmazonS3ReadOnlyAccess AWS managed policy ရှိပြီး S3 get၊ list နှင့် describe လုပ်ဆောင်ချက်များ ပါဝင်သည်။ EC2-Admin ၏ inline policy တွင် ec2:Describe*၊ ec2:StartInstances၊ ec2:StopInstances နှင့် cloudwatch:DescribeAlarms ကို ခွင့်ပြုထားသည်။



ပုံ 3 EC2-Support group ၏ AmazonEC2ReadOnlyAccess policy ကို စစ်ဆေးထားသည်။



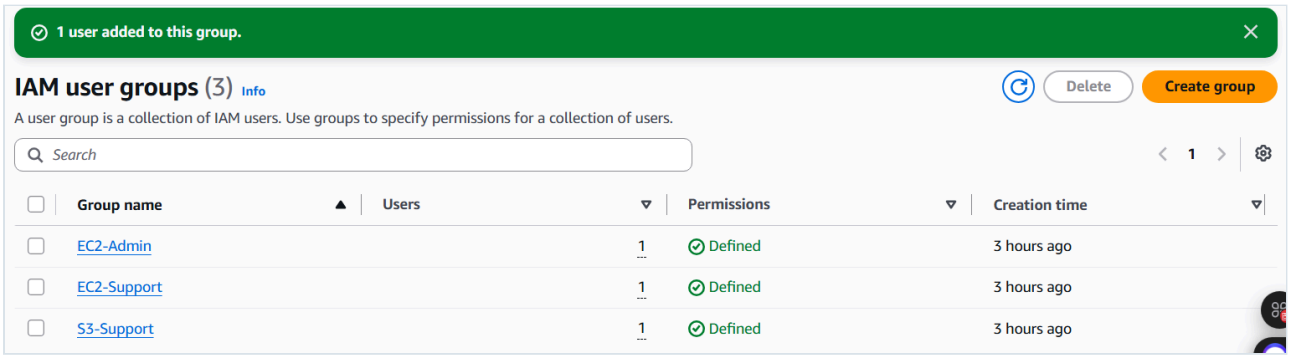
ပုံ 4 S3-Support group ၏ AmazonS3ReadOnlyAccess policy ကို စစ်ဆေးထားသည်။



ပုံ 5 EC2-Admin inline policy တွင် describe၊ start နှင့် stop action များ ပါဝင်သည်။

၄.၃ User များကို group ထဲသို့ ထည့်သွင်းခြင်း

Business scenario အတိုင်း user-1 ကို S3-Support၊ user-2 ကို EC2-Support၊ user-3 ကို EC2-Admin group သို့ ထည့်သွင်းခဲ့သည်။ ထည့်သွင်းပြီးနောက် group သုံးခုစလုံး၏ user count သည် 1 ဖြစ်ကြောင်း console က ပြသသည်။



ပုံ 6 Group သုံးခုစလုံးတွင် user တစ်ဦးစီ ရှိနေကြောင်း အတည်ပြုထားသည်။

၄.၄ IAM sign-in URL အသုံးပြုခြင်း

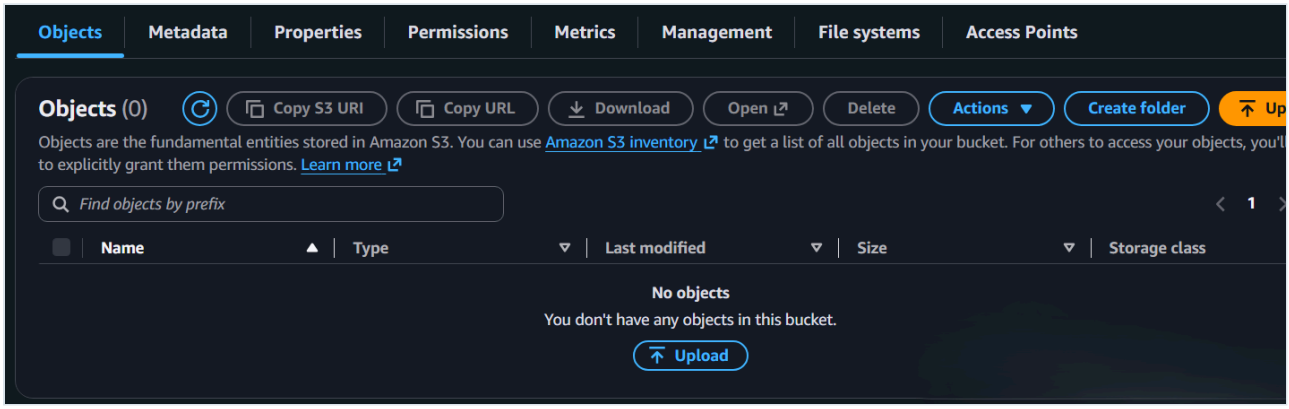
IAM Dashboard တွင် lab account ၏ IAM user sign-in URL ကို ရှာဖွေပြီး private browser window မှ user-1၊ user-2 နှင့် user-3 အဖြစ် သီးခြားဝင်ရောက်စမ်းသပ်ခဲ့သည်။ Sign-in URL နှင့် credentials များကို portfolio အထောက်အထားတွင် မဖော်ပြထားပါ။

၅ Access testing results

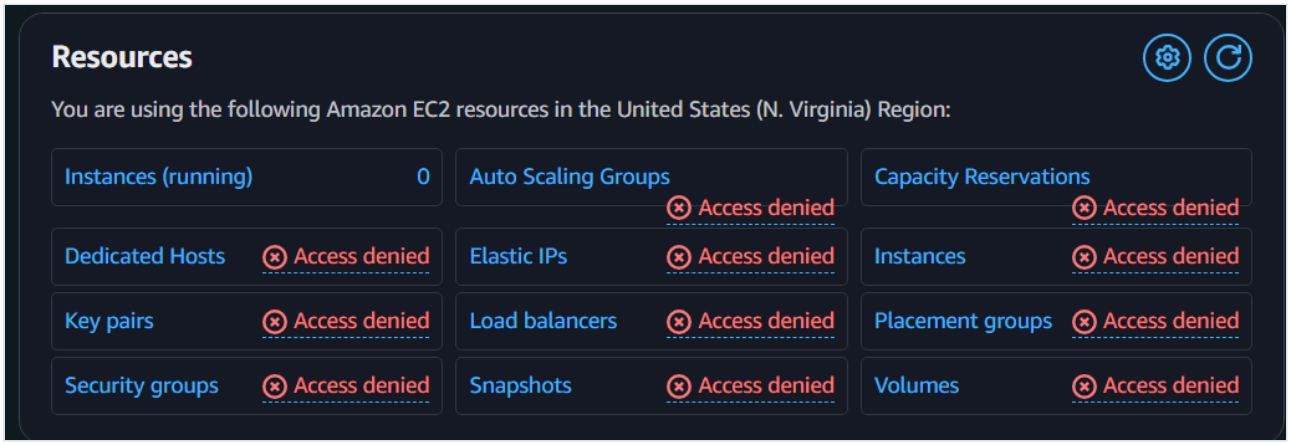
IAM user တစ်ဦးချင်းစီအဖြစ် sign in ဝင်ပြီး service စာမျက်နှာများကို လက်တွေ့စမ်းသပ်ခဲ့သည်။ အောက်ပါရလဒ်များသည် ပုံများတွင် မြင်ရသော outcome ကိုသာ ဖော်ပြသည်။

၅.၁ user-1 S3-Support

user-1 သည် S3 bucket စာမျက်နှာသို့ ဝင်ရောက်ပြီး bucket အတွင်းကို ဖွင့်ကြည့်နိုင်ခဲ့သည်။ Screenshot တွင် object count 0 ဖြစ်သောကြောင့် object တစ်ခုကို ဖတ်ရှုနိုင်ခဲ့သည်ဟု မဆိုနိုင်ပါ။ EC2 Instances ဘက်တွင် resource များအတွက် Access denied ပြသခဲ့ပြီး EC2 ကြည့်ခွင့်မရှိကြောင်း အတည်ပြုသည်။



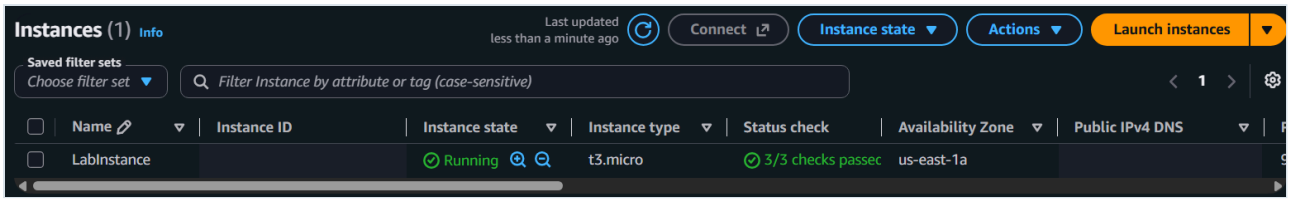
ပုံ 7 user-1 session တွင် S3 bucket ကို ဖွင့်ကြည့်နိုင်ပြီး အတွင်း၌ object မရှိသည်ကို မြင်ရသည်။



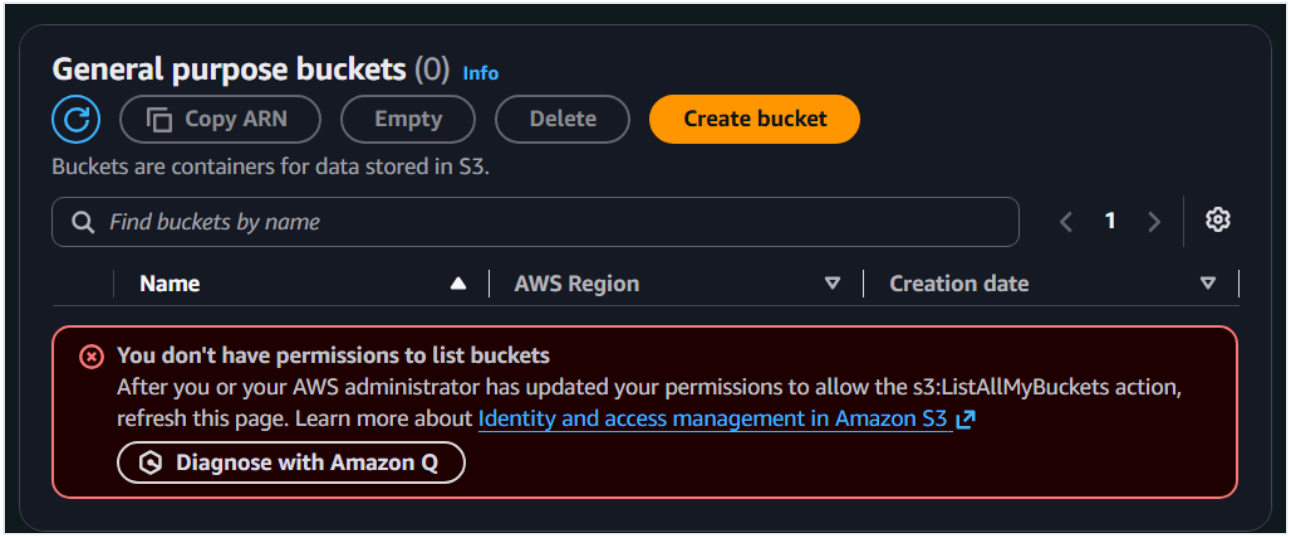
ပုံ 8 user-1 session ၏ EC2 dashboard တွင် resource access denial များ ပြသသည်။

၅.၂ user-2 EC2-Support

user-2 သည် EC2 Instances စာမျက်နှာတွင် Running state ရှိသော instance ကို ကြည့်နိုင်ခဲ့သည်။ S3 Buckets စာမျက်နှာတွင် bucket list ပြရန် permission မရှိကြောင်း error ပြသခဲ့သည်။ EC2 stop action ကို user-2 ဖြင့် စမ်းထားသော screenshot မပါသဖြင့် stop denial ကို တိုက်ရိုက်အတည်မပြုထားပါ။



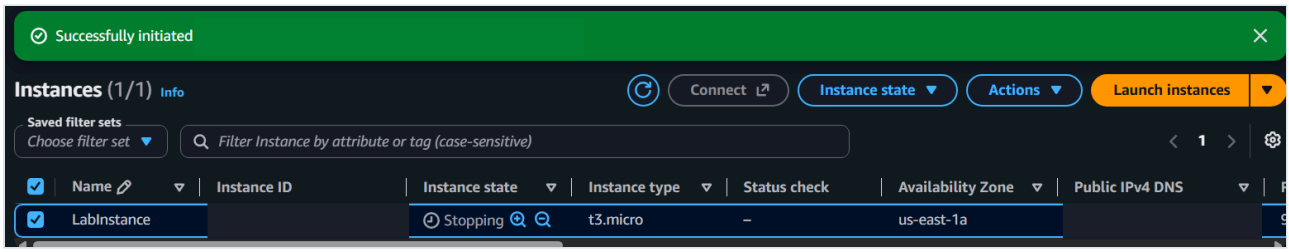
ပုံ 9 user-2 သည် Running EC2 instance ကို ကြည့်နိုင်ခဲ့သည်။



ပုံ 10 user-2 တွင် S3 bucket list ကြည့်ခွင့်မရှိကြောင်း console က ပြသသည်။

၅.၃ user-3 EC2-Admin

user-3 သည် EC2 instance stop action ကို ဆောင်ရွက်ခဲ့ရာ success notification ပေါ်လာပြီး instance state သည် Stopping ဖြစ်သွားသည်။ ဤပုံက ec2:StopInstances ခွင့်ပြုချက်ကို လက်တွေ့အတည်ပြုသည်။ StartInstances ကို policy ထဲတွင် တွေ့ရသော်လည်း start action ကို စမ်းထားသော ပုံမပါပါ။



ပုံ 11 user-3 ၏ stop request အောင်မြင်ပြီး instance state သည် Stopping သို့ ပြောင်းသည်။

User	ခွင့်ပြုထားသော access	Screenshot ဖြင့် အတည်ပြုထားသော ရလဒ်
user-1	S3 read only	S3 bucket ဖွင့်နိုင်၊ EC2 access denied
user-2	EC2 read only	EC2 instance ကြည့်နိုင်၊ S3 list denied
user-3	EC2 view, start, stop	EC2 stop request အောင်မြင်၊ state Stopping

၆ Key technical learnings

- Group အလိုက် permission သတ်မှတ်ခြင်းက တာဝန်တူ user များကို စနစ်တကျ စီမံရန် အထောက်အကူပြုသည်။
- AWS managed policy ကို ပြန်လည်အသုံးပြုနိုင်ပြီး inline policy ကို သီးသန့် group တစ်ခုနှင့် ချိတ်ထားနိုင်သည်။
- Policy ရှိကြောင်း စစ်ဆေးခြင်းနှင့် user အဖြစ် sign in ဝင်ပြီး outcome ကို စမ်းသပ်ခြင်း နှစ်ခုစလုံး လိုအပ်သည်။
- Access denied ရလဒ်များက မလိုအပ်သော service access ကို ပိတ်ထားကြောင်း ပြနိုင်သည်။
- Policy တွင် ခွင့်ပြုထားသော action နှင့် screenshot ဖြင့် လက်တွေ့အတည်ပြုထားသော action ကို ခွဲဖော်ပြရသည်။

၇ Skills demonstrated

AWS IAM user နှင့် group စစ်ဆေးခြင်း၊ AWS managed နှင့် inline policy ဖတ်ရှုခြင်း၊ user to group assignment၊ Amazon S3 နှင့် EC2 permission testing၊ access denied message အနက်ဖွင့်ခြင်း၊ least privilege access design နှင့် screenshot evidence documentation။

၈ နိဂုံးချုပ်

ဤ lab တွင် IAM group သုံးခုကို တာဝန်အလိုက် အသုံးပြုပြီး user သုံးဦး၏ access ကို ခွဲဝေစမ်းသပ်ခဲ့သည်။ S3 read access၊ EC2 read access နှင့် EC2 stop permission တို့သည် သက်ဆိုင်ရာ user session များတွင် မျှော်မှန်းထားသည့်အတိုင်း အလုပ်လုပ်ခဲ့ပြီး ခွင့်မပြုထားသည့် service access များတွင် denial ပြသခဲ့သည်။ ယင်းက least privilege နှင့် group based permission management ကို လက်တွေ့နားလည်နိုင်စေသည်။

CV နှင့် LinkedIn အတွက် အကျဉ်းချုပ်

AWS IAM lab တစ်ခုတွင် users၊ groups၊ AWS managed policies နှင့် inline policy များကို စစ်ဆေးကာ S3 နှင့် EC2 တာဝန်အလိုက် access ခွဲဝေခဲ့သည်။ IAM user သုံးဦးဖြင့် sign in ဝင်စမ်းသပ်ပြီး S3 read access၊ EC2 read access၊ access denial နှင့် EC2 instance stop success တို့ကို screenshot evidence ဖြင့် မှတ်တမ်းတင်ခဲ့သည်။

အခြေခံ lab guide AWS Cloud Technical Essentials Introduction to AWS Identity and Access Management Version 1.0.1